PROCEDIMIENTO DE PROTECCIÓN DE PROYECTOS IT

HISTORIAL DEL DOCUMENTO			
Versión	**Resumen de modificaciones**	**Fecha de entrada**	**Sustituye a (Código, revisión)**
01	Primera versión del documento.	26/02/2025	N/A

REGISTRO DE FIRMAS			
Función:	**Elaborado por:**	**Revisado por:**	**Aprobado por:**
Departamento:	Responsable del SGSI	Dirección	Jefe de seguridad (o suplente)
Nombre:	David Pozo	Carlos Rodrigo	Carlos Zúñiga
Firma:	Firmado por POZO SANCHEZ DAVID - ***6992** el día 26/02/2025	Firmado por RODRIGO RIVERO, CARLOS (AUTENTICACIÓN) el día 26/02/2025	Firmado por ***8264** CARLOS ZUÑIGA (R: ****8690*) el día 26/02/2025 con un
Fecha:	26/02/2025	26/02/2025	26/02/2025

CONTENIDO

1 OBJETIVO 4
2 ALCANCE 4
3 NORMATIVA APLICABLE 4
4 DESARROLLO 4
5 REFERENCIAS 5
6 ANEXO A 6
7 ANEXO B 22
8 ANEXO C 33
9 ANEXO D 39

1 OBJETIVO

El objetivo de este documento es establecer requisitos y directrices en materia de seguridad de la información en los acuerdos de servicios prestados por terceros. Dichas directrices deberán ser un modelo para seguir para los responsables de dichos servicios.

2 ALCANCE

Esta normativa se aplica a todo el personal de que participe en los procesos de contratación de terceros.

Riesgos

Los riesgos principales son los siguientes:

- Suplantación de identidad.
- Robo o divulgación de información.
- Software malicioso.
- Ciberataques.
- Imposibilidad de detección de acciones no autorizadas.

3 NORMATIVA APLICABLE

Es aplicable toda la normativa establecida en el documento de **RGS_1 NORMATIVA APLICABLE**, que se actualizara de forma periódica Las Políticas, Normas y Procedimientos dentro del alcance.

4 DESARROLLO

La política de seguridad de la información de SPIKA TECH establece que todos los recursos, entre los cuales se incluye un servicio prestado por un proveedor o tercero, deben ser protegidos acorde a los requisitos de negocio a través de medidas de seguridad, de acuerdo con criterios de evaluación de riesgos y las estrategias de Seguridad de la Información establecidas en la entidad.

Es por ello por lo que, frente a una amenaza de seguridad de un servicio IT provisto por un tercero, se establece el requisito de incluir, en el correspondiente acuerdo contractual, cláusulas en materia de seguridad de la información que garanticen los requisitos de negocio vinculados al servicio en cuestión. Para ello, se definen:

- **Tipo A:** La prestación del servicio requerirá del almacenamiento de datos de SPIKA TECH (de forma continuada) en sistemas que son responsabilidad del proveedor, siempre y cuando se trate de datos que van más allá de los datos de contacto profesional de las personas involucradas en el servicio. A este tipo de servicios deberán solicitarse las cláusulas disponibles en el Anexo A.
- **Tipo B:** La prestación del servicio se lleva a cabo mediante conexión en remoto a información que reside en SPIKA TECH dispositivos responsabilidad del proveedor ya sea desde las instalaciones del proveedor o bien estando en las instalaciones de SPIKA TECH. A este tipo de servicios deberán solicitarse las cláusulas disponibles en el Anexo B.
- **Tipo C:** Para la prestación del servicio se accede a información de SPIKA TECH mediante dispositivos propios o bajo el control de SPIKA TECH. A este tipo de servicios deberán solicitarse las cláusulas de seguridad disponibles en el Anexo C.

Para aquellos otros servicios no relacionados con proyectos TI se les solicitará la confirmación de la checklist del Anexo D.

5 REFERENCIAS

- ISO 27001:2022:
    - 5.8 Seguridad de la información en la gestión de proyectos.
    - 5.19 Seguridad de la información en las relaciones con los proveedores.
    - 5.20 Abordar la seguridad de la información dentro de los acuerdos con proveedores

6 ANEXO A

Políticas y regulaciones de seguridad de la información

a. El PROVEEDOR deberá desarrollar, mantener y aplicar medidas de seguridad técnicas, organizativas o lógicas apropiadas para proteger cualquier dato no público del CLIENTE, incluidos los datos personales, del acceso o divulgación no autorizados, la destrucción accidental o ilícita o la pérdida o alteración accidental.

b. EL PROVEEDOR garantiza que el acceso a los datos del CLIENTE para casos de soporte estará restringido a un número limitado de personal autorizado por el CLIENTE, en función de las necesidades del negocio, la necesidad de saber y los privilegios mínimos requeridos.

c. El PROVEEDOR tomará en cuenta la naturaleza, alcance y complejidad de sus operaciones al formular el Reglamento Interno y lo actualizará periódicamente.

d. EL PROVEEDOR no accederá a los Datos del CLIENTE a menos que el CLIENTE lo apruebe.

e. La política y normativa de seguridad de la información del PROVEEDOR deberá estar alineada con los estándares internacionales de referencia, ISO 27002, NIST o similares.

f. El PROVEEDOR deberá contar con las herramientas y recursos necesarios para la implementación de su política y normativa de seguridad de la información.

g. El PROVEEDOR deberá monitorear continuamente el cumplimiento de las políticas y regulaciones de seguridad de la información, y podrá demostrar dicho cumplimiento al CLIENTE cuando sea requerido.

h. El PROVEEDOR debe asignar responsabilidades de seguridad de la información a personas específicas. Sus responsabilidades deben incluir el cumplimiento de la protección de datos, así como el mantenimiento de la confidencialidad, integridad y disponibilidad de los datos y servicios del CLIENTE.

Seguridad relacionada con los recursos humanos

i. El PROVEEDOR deberá realizar acciones de concienciación entre su personal y todos aquellos terceros que, debido al servicio prestado, pudieran tener acceso a la información del CLIENTE.

j. Será responsabilidad del PROVEEDOR que sus empleados o colaboradores:
   i. Conozca cuánta información relativa a la protección de datos pone a su disposición el propio proveedor.
   ii. Realizar la capacitación en materia de Seguridad de la Información impartida y seguir las buenas prácticas y recomendaciones divulgadas en la misma, garantizar que los datos del Cliente se procesen de forma legal y de acuerdo con los requisitos de seguridad tanto del CLIENTE como del PROVEEDOR.
   iii. Tomar conciencia de la importancia de la seguridad de la información que el PROVEEDOR le confía o pone a su disposición para el desempeño de sus funciones.
   iv. Infórmese y comprométase observar la debida reserva, confidencialidad y secreto respecto de los datos personales a los que, con motivo del ejercicio de sus funciones, tenga acceso. Esta obligación subsistirá aún después de finalizar su relación.

Gestión de activos

k. El PROVEEDOR deberá tener un inventario de todos los activos utilizados para almacenar o procesar datos de CLIENTES. Antes de desactivar cualquier dispositivo que contenga datos de CLIENTES, debe borrar de forma segura el dispositivo.

Control de acceso

l. El PROVEEDOR deberá contar con procedimientos y soluciones de control de acceso para limitar el acceso a los datos del CLIENTE.

m. Para ello, el PROVEEDOR deberá contar, como mínimo, con las siguientes medidas de seguridad:
   i. Procedimiento de alta/registro, modificación y baja/revocación de usuarios con acceso a sistemas o aplicaciones.

ii. Registro o listado de usuarios con acceso a sistemas o aplicaciones, incluyendo todo tipo de requisitos de acceso importantes, como acceso a la red, a la nube, acceso móvil y acceso remoto.

iii. Revisión periódica de permisos en sistemas o aplicaciones.

iv. Revisión periódica de accesos a sistemas o aplicaciones.

v. Registro/log de accesos a sistemas/aplicaciones: intentos exitosos y fallidos, accesos con perfil de administrador, modificaciones o borrados de datos realizados.

vi. Se implementó una política de contraseñas segura (longitud, complejidad, historial, etc.)

- Longitud mínima de la contraseña: 10 caracteres
- Validez máxima de la contraseña: 60 días
- Validez mínima de la contraseña: 1 día
- Tiene en cuenta un historial de contraseñas del usuario al crear la contraseña cuando caduca: 24 contraseñas
- Reglas de complejidad de contraseñas: mayúsculas, minúsculas, números y símbolos.

vii. Política de bloqueo de cuenta después de 10 intentos fallidos: cuentas bloqueadas; política de cierre de sesión después de un período de inactividad

viii. Procedimientos de distribución y restablecimiento de contraseñas que garantizan la seguridad y el no acceso de terceros no autorizados.

ix. Sistemas de gestión de acceso de usuarios que permitan garantizar su identificación inequívoca. Todos los usuarios deberán utilizar la autenticación de doble factor y para ello deberán contar con un dispositivo móvil.

Criptografía

n. EL PROVEEDOR debe garantizar que todos los datos del CLIENTE estén encriptados, tanto en reposo como en tránsito.

o. EL PROVEEDOR debe implementar medidas de seguridad adecuadas para proteger los datos del CLIENTE, tanto en reposo como en tránsito.

p. El PROVEEDOR deberá contar con procedimientos para el manejo seguro de las claves de cifrado, las cuales podrán ser conservadas por el CLIENTE en caso de ser requerido por éste.

Seguridad física y ambiental

q. El PROVEEDOR deberá implementar medidas para controlar el acceso físico a los sistemas de información, sean automatizados o no automatizados (papel). Solamente el personal autorizado por el PROVEEDOR deberá estar autorizado para acceder físicamente a dichos sistemas de información.

r. Las normas de seguridad física deberán incluir, como mínimo, las siguientes medidas:

   i. Tener siempre visibilidad sobre personas no autorizadas a acceder a la información.

   ii. No deje abiertas las puertas de acceso a oficinas o habitaciones si no están supervisadas.

   iii. No dejar pantallas de ordenador u otros sistemas de visualización de datos, así como documentación sobre mesas, a la vista de personas no autorizadas.

   iv. Bloquear las pantallas de los equipos de cómputo siempre que sea necesario ausentarse temporalmente del lugar de trabajo.

   v. No mantener conversaciones relacionadas con los procesos de negocio de la Empresa y/o Clientes en presencia de personas no autorizadas a conocer dicha información.

   vi. No coloque impresoras, escáneres, faxes o dispositivos portátiles o extraíbles, como USB, discos duros externos, etc., al alcance de personas distintas al PROVEEDOR.

   vii. No deje el correo postal al alcance de usuarios no autorizados y

   viii. Cierre los armarios y las puertas al cerrar la oficina.

ix. Asegure las computadoras portátiles con cerraduras de seguridad al final del día o durante ausencias prolongadas.

s. Además, el acceso a instalaciones sensibles como el centro de procesamiento de datos debe incluir las siguientes medidas:

i. Registro de acceso físico a las instalaciones del PROVEEDOR

ii. Solicitudes de acceso/autorización de acceso a las instalaciones del PROVEEDOR.

iii. Revisión periódica de permisos de acceso.

iv. Sistemas de detección y mitigación de incendios e inundaciones, implantados, con revisiones o pruebas periódicas realizadas.

Seguridad de operaciones

t. El PROVEEDOR deberá implementar y operar medidas de protección de los sistemas de información de acuerdo con su normativa de seguridad de la información. Asimismo, deberá incluir al menos los siguientes aspectos:

i. Realizar análisis de vulnerabilidades y pruebas de penetración en todas las aplicaciones e infraestructuras que alojan datos de CLIENTES

ii. Sistemas/aplicaciones con vulnerabilidades mitigadas:

- El PROVEEDOR contará con un proceso para identificar y gestionar las amenazas cibernéticas y realizar pruebas de seguridad periódicas. El tipo y frecuencia de dichas pruebas serán presentadas por el PROVEEDOR y acordadas con el CLIENTE. Los resultados de dichas pruebas también deberán ser comunicados al CLIENTE si así lo solicita. El CLIENTE no se verá afectado por las pruebas de seguridad y rendimiento ejecutadas por otras partes, como otros Clientes del PROVEEDOR.
- El PROVEEDOR utilizará un estándar comúnmente aceptado para clasificar vulnerabilidades.
- El PROVEEDOR contará con procedimientos para asegurar que las vulnerabilidades. Los problemas técnicos se evalúan y mitigan de manera oportuna y de acuerdo con las normas internas del Destinatario

del Servicio, lo antes posible, pero en un plazo máximo de 30 días para aquellos de severidad crítica/alta, 90 días para los de severidad media y 180 días para los de menor severidad desde el día de su identificación.

iii. Sistemas/aplicaciones con los últimos parches o actualizaciones instalados.

iv. Sistemas antimalware:

- El PROVEEDOR contará con medidas técnicas adecuadas para mitigar el riesgo de que personas no autorizadas accedan a los sistemas o infectarlos con software malicioso. Dichas medidas pueden incluir, entre otras, medidas antivirus basadas en host y en red, software avanzado de protección contra amenazas, cortafuegos, sistemas de detección o prevención de intrusiones (IDS/IPS), etc.
- Se establecerán procedimientos para garantizar que las soluciones implementadas se mantengan actualizadas en todo momento, funcionen según lo previsto y se monitoreen y se actúe en consecuencia sobre las alertas creadas por estas soluciones.

v. Sistemas de prevención de fuga de información.

vi. Sistemas de registro de actividades realizadas por los usuarios que permiten la correlación de eventos y generación de alertas.

u. El PROVEEDOR deberá implementar medidas de protección de los puestos de trabajo de acuerdo con sus normas y procedimientos, asegurando el cumplimiento de los siguientes aspectos:

i. Cifrado de discos duros en ordenadores.

ii. Inventario con asignación de propietario de cada activo de inventario y responsabilidades.

iii. Uso adecuado de los activos.

iv. Formateo de información en dispositivos reutilizables.

v. El PROVEEDOR deberá realizar copias de respaldo de conformidad con los procedimientos que haya desarrollado, debiendo los datos estar encriptados en las copias.

Gestión de riesgos

a. El PROVEEDOR analizará los riesgos de la información al menos una vez al año, así como en caso de cambios que puedan afectar la Seguridad de la Información.

b. La metodología de evaluación de riesgos estará documentada y basada en las mejores prácticas. El PROVEEDOR contará con un plan de mitigación de riesgos documentado.

c. El PROVEEDOR documentará los análisis de riesgos y sus decisiones sobre medidas y pondrá a disposición extractos del registro de riesgos relacionados con los servicios prestados a solicitud del CLIENTE.

Ciberseguridad

a. El PROVEEDOR contará con una política y estrategia de ciberseguridad.

b. El PROVEEDOR se asegurará de que exista una asignación clara de responsabilidades en materia de ciberseguridad dentro de sus operaciones.

c. El PROVEEDOR designará una persona responsable de dirigir y coordinar los trabajos de ciberseguridad.

d. Se utilizará un marco de ciberseguridad para garantizar que el trabajo de ciberseguridad realizado por el PROVEEDOR sea estructurado y metódico.

e. El marco de ciberseguridad se basará en las mejores prácticas o estándares, por ejemplo, el Marco de Ciberseguridad del NIST.

f. La ciberrespuesta y ciberresiliencia del servicio prestado estará en consonancia con la criticidad y clasificación de la información del servicio prestado. Esta clasificación estará basada en los requisitos impuestos a la Confidencialidad, Integridad y Disponibilidad de la información en sus operaciones, y los datos del CLIENTE serán clasificados como confidenciales (o similares).

g. Los elementos del marco de ciberseguridad se probarán antes y periódicamente después de su uso utilizando diversas metodologías.

Documentación de sistemas informáticos

a. El PROVEEDOR dispondrá de documentación de cada uno de los sistemas informáticos que sean importantes para la operación. Estos sistemas se especificarán en un listado que será revisado y actualizado periódicamente en caso de ser necesario.

Seguridad de las comunicaciones

a. El PROVEEDOR deberá implementar medidas de control que minimicen la exposición de los datos del CLIENTE, tanto interna como externamente. Para ello, sus normas y procedimientos deberán considerar al menos los siguientes aspectos:

   i. Infraestructura de seguridad perimetral para controlar el acceso a la red corporativa de la empresa.

   ii. Cifrado de comunicaciones y/o información saliente de un sistema particular.

   iii. Monitoreo y registro de eventos en las comunicaciones.

   iv. Protección de elementos de red.

   v. Mecanismos de control de acceso y encriptación a través de protocolos de redes inalámbricas seguras.

Comunicación segura de datos de extremo a extremo

La comunicación de datos entre el CLIENTE y el PROVEEDOR, entre los centros de datos del PROVEEDOR, entre los Clientes del CLIENTE y PROVEEDOR, así como cualquier otra vía de comunicación dentro de los centros de servicio y centros de datos del PROVEEDOR, deberá ser protegida por el PROVEEDOR de extremo a extremo.

Datos del CLIENTE encriptados

El PROVEEDOR garantiza que no se podrá acceder a los datos en reposo del CLIENTE.

Durante los Proyectos de Implementación, el PROVEEDOR establecerá y presentará un proceso documentado de gestión de claves y un tipo de cifrado utilizado para proteger los Datos del CLIENTE basado en las mejores prácticas.

Adquisiciones, desarrollo y mantenimiento de sistemas de información

w. El PROVEEDOR deberá contar con procedimientos para la revisión y pruebas, tanto funcionales como de seguridad, de los productos de software adquiridos antes de su implementación.

x. El PROVEEDOR deberá contar con un modelo o método de desarrollo seguro que incluya:

   i. Seguridad en la fase de diseño (requisitos de seguridad)

   ii. Buenas prácticas de desarrollo seguro

   iii. Controles de verificación de requisitos

   iv. Control de versiones

   v. Realizar revisiones de código.

y. Los datos utilizados para las pruebas por parte del PROVEEDOR deberán ser ficticios o, en su caso, anonimizados/disociados.

z. El PROVEEDOR deberá disponer de medidas de almacenamiento seguro y control de acceso al código fuente de los programas.

Prácticas y metodología para el desarrollo y uso de software seguro

a. EL PROVEEDOR desarrollará y gestionará el software de acuerdo con las mejores prácticas establecidas, por ejemplo, OWASP, seguridad por diseño, garantía de calidad y pruebas de seguridad.

b. El PROVEEDOR no utilizará los datos del CLIENTE para fines de desarrollo y pruebas, salvo autorización expresa del CLIENTE.

c. EL PROVEEDOR adoptará las mejores prácticas de la industria para el modelado de amenazas, como STRIDE, Trike, PASTA o similares, en los procesos de desarrollo para garantizar que se tengan en cuenta las amenazas comunes durante el desarrollo de nuevos sistemas y aplicaciones y la selección de medidas de seguridad.

Relación con proveedores

a. El PROVEEDOR, sin perjuicio de las autorizaciones de subcontratación requeridas, deberá contar con procedimientos para identificar, clasificar y evaluar

la idoneidad de aquellos terceros contratados por éste que pudieran afectar el servicio prestado al CLIENTE o tener acceso a los datos del CLIENTE

b. Los procedimientos definidos por el PROVEEDOR deberán permitir, como mínimo, validar que se disponga de los siguientes aspectos:

   i. Cláusulas relativas a la seguridad de la información en los contratos con proveedores de servicios: requisitos de seguridad en la cadena de suministro y/o servicio TIC.

   ii. Acuerdos de Nivel de Servicio con proveedores de servicios TIC: descripción del servicio, nivel de servicio, mecanismos de seguridad, gestión del servicio, gestión del cambio...

   iii. Revisiones de acuerdos de nivel de servicio TIC con proveedores: Informes de servicio, auditorías de servicio realizadas.

   iv. Existencia de planes adecuados de transferencia de servicios entre proveedores en caso de incumplimientos reiterados de los acuerdos de nivel de servicio.

   v. Solicitud a los proveedores de certificados oficiales de acuerdo al estándar de seguridad en función del servicio prestado.

Gestión de incidentes de seguridad de la información

a. El PROVEEDOR deberá contar con un procedimiento para gestionar incidencias de seguridad de información y reportar, identificar y gestionar incidentes, para asegurar una gestión eficaz y estandarizada de los incidentes y aprender de cualquier incidente de seguridad de la información, sospechado, real o potencial, relacionado con los servicios prestados al CLIENTE (“Incidente de Seguridad”). »). Este procedimiento también debe incluir:

   vi. roles y responsabilidades para diferentes escenarios (por ejemplo, errores, fallos de funcionamiento o ataques cibernéticos);

   vii. procedimientos para identificar, analizar y resolver la causa raíz de uno o más incidentes;

   viii. procedimientos Respuesta a incidentes para mitigar los impactos relacionados con incidentes para minimizar la degradación de los servicios; y

ix. Planes de comunicación externa para funciones y procesos con el fin de colaborar con las partes interesadas relevantes y recuperarse del incidente de manera oportuna.

b. Después de tener conocimiento de un Incidente de Seguridad, el PROVEEDOR deberá:

i. Notificar al CLIENTE lo antes posible, en el plazo máximo de 24 horas.

ii. Hacer todo lo que esté a su alcance para evitar dicha violación o mitigar sus consecuencias para minimizar el impacto comercial negativo para el CLIENTE;

iii. Informar continuamente al CLIENTE de las medidas que el PROVEEDOR adopte o vaya a adoptar;

iv. Obtener la autorización del CLIENTE, por escrito y con antelación, para cualquier comunicación, notificación o anuncio público sobre el Incidente de Seguridad, y

v. Realizar cualquier acción adicional solicitada por el CLIENTE, incluyendo colaborar en las investigaciones del CLIENTE relacionadas con el Incidente de Seguridad, si lo hubiera.

Gestión de la continuidad del negocio

a. El PROVEEDOR deberá contar con un plan de continuidad de negocio documentado y alineado con los requerimientos del CLIENTE a nivel de RTO y RPO del servicio.

b. El PROVEEDOR deberá realizar pruebas del plan de continuidad del negocio y recuperación ante desastres, al menos anualmente.

c. La documentación describirá al menos cómo se utilizarán los sistemas de TI, la funcionalidad, el diseño interno relevante y la descripción de las rutinas operativas.

2. CLÁUSULA CONDICIONADA A LA SUBCONTRATACIÓN TOTAL O PARCIAL DEL SERVICIO CONTRATADO

Las cláusulas de este apartado deberán incluirse siempre que el PROVEEDOR subcontrate a terceros el servicio que está contratando el CLIENTE, ya sea parcial o totalmente.

SEGURIDAD DE LOS EMPLEADOS

a. Establece la necesidad de establecer vínculos para asegurar el cumplimiento por parte de terceros de todas las políticas de Seguridad de la Información de la Compañía.

b. Los asesores, colaboradores externos y proveedores tendrán la misma obligación de cumplir con la política de Seguridad de la Información que los empleados de la Compañía. Por cada asesor, colaborador externo o PROVEEDOR que tenga acceso a la información de la Compañía, se le asignará un jefe de proyecto que velará por el cumplimiento de todas las políticas de Seguridad de la Información de la Compañía.

c. Todo acceso a las instalaciones de procesamiento de información del Destinatario del Servicio y la comunicación de información por parte de terceros externos deberán ser controlados por el PROVEEDOR, y los controles deberán ser acordados y definidos formalmente en el contrato entre el PROVEEDOR y su subcontratista.

d. El PROVEEDOR implementará controles para gestionar (identificar, clasificar y, cuando sea necesario, mitigar) los riesgos relacionados con los subcontratistas y tendrá en cuenta los riesgos para el CLIENTE y los requisitos de seguridad descritos en el acuerdo al diseñar los controles. Los riesgos se reevaluarán periódicamente durante la duración del compromiso entre el PROVEEDOR y sus subcontratistas.

e. Los terceros del PROVEEDOR sólo tendrán acceso a los sistemas/aplicaciones que estén procesando datos del CLIENTE con la aprobación explícita del CLIENTE.

GESTIÓN DE OPERACIONES

a. Todos los proyectos de TI que incluyan recursos externos (contratistas, proveedores de servicios, etc.) deben cumplir con todas las políticas corporativas en materia de contratos con terceros. Esto incluye todas las políticas de seguridad, TI, recursos humanos y legales.

CONTROL DE ACCESO

a. Si un tercero requiere una conexión perpetua o de largo plazo, la conexión debe establecerse utilizando métodos de autenticación de usuario ampliados (por ejemplo, tokens manuales, proceso de desafío/respuesta basado en software, módems de devolución de llamada, etc.), aprobados para la seguridad de la información.

b. Todas las cuentas para el acceso de terceros a las redes o recursos de información de la Compañía deben ser habilitadas con la aprobación de la gerencia de la Compañía y deben ser deshabilitadas cuando los servicios prestados hayan sido completados. La cuenta debe estar habilitada por un tiempo limitado específico que no exceda los seis (6) meses a partir de la fecha de emisión de la cuenta. Al vencimiento, la cuenta puede ser extendida hasta una fecha posterior, no más de seis (6) meses a partir de la fecha de extensión de la cuenta. La persona asignada, la fecha, la hora, el grupo y el propósito de uso deben estar documentados.

c. Para solicitar el acceso de terceros a un recurso de información de la Compañía, el solicitante debe preparar una descripción de la naturaleza del acceso y proporcionársela al propietario de la información y al líder de la unidad de negocios correspondiente para su aprobación formal. El líder de la unidad de negocios correspondiente y el propietario de la información deben aprobar la solicitud utilizando la herramienta proporcionada para este fin. La solicitud debe incluir una descripción general de los motivos por los que se necesita el acceso y las necesidades comerciales específicas que se deben satisfacer. La solicitud también debe incluir la duración del acceso que se necesitará (por ejemplo: hasta el final del proyecto, hasta una fecha determinada, de forma permanente o hasta que expire un contrato específico).

SERVICIOS DE TERCEROS

a. Para todas las relaciones con proveedores externos se debe suscribir un contrato que contenga los términos y condiciones adecuados. Debe existir una lista de contratos modelo disponibles, elaborada por el área de asesoría legal de la Compañía.

b. En todos los acuerdos con proveedores externos deberán incluirse, como mínimo, las siguientes condiciones generales:

i. Una cláusula de “derecho a auditoría” que garantiza que los empleados de la Compañía o sus representantes autorizados podrán evaluar física y lógicamente el entorno de control de seguridad de un PROVEEDOR externo.

ii. Especificar que el tercero será responsable de informar inmediatamente al Director de la Unidad de Negocios de la Compañía responsable del contrato sobre cualquier violación conocida o sospechada de la Política de Seguridad de la Información de la Compañía.

iii. Exigir a los proveedores externos que firmen acuerdos de confidencialidad o NDA.

iv. Debe redactarse de forma que garantice que el PROVEEDOR está legalmente obligado a cumplir con la Política de Seguridad de la Información de la Compañía.

v. Incluir requisitos de seguridad y/o especificaciones de seguridad de forma explícita o por referencia basándose en una evaluación de riesgos.

vi. Establecer que todo software desarrollado por proveedores externos para la Compañía será propiedad de la Compañía y no podrá ser distribuido sin autorización previa por escrito de las unidades de Asesoría Legal y Cumplimiento Normativo.

vii. Identificar medidas objetivas y cuantificables para medir el desempeño que sean relevantes para el área de negocios respaldada por la subcontratación, que sean acordadas mutuamente y que puedan compararse fácilmente con criterios establecidos.

c. Los requisitos de seguridad del servicio de información subcontratado deben definirse e incorporarse en todos los acuerdos formales, como los acuerdos de servicio o los contratos entre la Compañía y el proveedor subcontratado. Los términos de los acuerdos formales deben firmarse y revisarse periódicamente. Los acuerdos formales con los proveedores de servicios deben especificar, como mínimo:

i. Responsabilidades del proveedor en materia de seguridad, requisitos de capacidad y requisitos de disponibilidad del servicio de red.

ii. La Compañía requiere que los proveedores externos implementen controles de seguridad que sean al menos tan estrictos como los controles utilizados por la Compañía para sus propias operaciones.

iii. Si la actividad subcontratada está relacionada con la gestión de firewalls, se deberá adjuntar como ejemplo la Política de Firewalls de la Compañía.

iv. Los puntos a conectar y los métodos de conexión, incluidos los tipos de servicios o protocolos de red.

v. Restricciones a los métodos de conexión y acceso a ciertos acuerdos de servicio para garantizar la continuidad operativa y la segregación de los componentes de la red.

vi. Adhesión a un proceso de gestión de cambios formalizado.

vii. Protocolo para la gestión de incidentes.

viii. Métodos para detectar y recuperar interrupciones del servicio.

ix. Protección de datos confidenciales durante el almacenamiento y el tránsito, garantizando la adecuada destrucción de archivos, cuando corresponda.

x. Restricción de acceso para partes obligadas contractualmente.

xi. Consideraciones sobre tecnologías emergentes y disposiciones para reemplazar, reducir o agregar servicios en función de los cambios tecnológicos.

xii. En el caso de la subcontratación internacional, se debe determinar el país cuyas leyes y regulaciones se aplicarán.

xiii. La Compañía está autorizada a realizar controles de seguridad periódicos:

1. El PROVEEDOR realizará, a su cargo, una auditoría de seguridad al menos una vez al año. Esta auditoría verificará el cumplimiento de las normas y procedimientos de seguridad acordados.
2. El Destinatario del Servicio podrá utilizar a un tercero o a su propio personal interno para realizar una auditoría independiente o para supervisar la auditoría del PROVEEDOR.

3. El PROVEEDOR corregirá prontamente cualquier deficiencia detectada en una auditoría de seguridad e informará al CLIENTE de las medidas correctivas adoptadas.

xiv. De conformidad con la ley, norma u orientación supervisora, los supervisores que tengan la autoridad regulatoria correspondiente deben tener acceso a todos los documentos, soportes de datos y sistemas del PROVEEDOR en la medida en que estén relacionados con el área subcontratada para llevar a cabo las tareas de revisión supervisora. La subcontratación de un área de negocios no podrá afectar la capacidad regulatoria o supervisora de cualquier autoridad supervisora que tenga jurisdicción sobre la persona jurídica que esté prestando el servicio subcontratado.

xv. Establecer criterios de aceptación y planes de pruebas.

d. También se debe considerar el requisito de que el PROVEEDOR mantenga una cobertura de seguro adecuada para cubrir el riesgo de cualquier incidente de seguridad.

7 ANEXO B

1. Políticas y normativas de seguridad de la información

El PROVEEDOR deberá desarrollar, mantener y aplicar medidas de seguridad técnicas, organizativas o lógicas apropiadas para proteger cualquier dato no público del CLIENTE, incluidos los datos personales, del acceso o divulgación no autorizados, la destrucción accidental o ilícita o la pérdida o alteración accidental.

a. EL PROVEEDOR garantiza que el acceso a los datos del CLIENTE para casos de soporte estará restringido a un número limitado de personal autorizado por el CLIENTE, en función de las necesidades del negocio, la necesidad de saber y los privilegios mínimos requeridos.

b. El PROVEEDOR tomará en cuenta la naturaleza, alcance y complejidad de sus operaciones al formular el Reglamento Interno y lo actualizará periódicamente.

c. EL PROVEEDOR no accederá a los Datos del CLIENTE a menos que el CLIENTE lo apruebe.

d. La política y normativa de seguridad de la información del PROVEEDOR deberá estar alineada con los estándares internacionales de referencia, ISO 27002, NIST o similares.

e. El PROVEEDOR deberá contar con las herramientas y recursos necesarios para la implementación de su política y normativa de seguridad de la información.

f. El PROVEEDOR deberá monitorear continuamente el cumplimiento de las políticas y regulaciones de seguridad de la información, y podrá demostrar dicho cumplimiento al CLIENTE cuando sea requerido.

g. El PROVEEDOR debe asignar responsabilidades de seguridad de la información a personas específicas. Sus responsabilidades deben incluir el cumplimiento de la protección de datos, así como el mantenimiento de la confidencialidad, integridad y disponibilidad de los datos y servicios del CLIENTE.

2. Seguridad relacionada con los recursos humanos

a. El PROVEEDOR deberá realizar acciones de concienciación entre su personal y todos aquellos terceros que, en razón del servicio prestado, pudieran tener acceso a la información del CLIENTE.

b. Será responsabilidad del PROVEEDOR que sus empleados o colaboradores:

   i. Conozca cuánta información relativa a la protección de datos pone a su disposición el propio PROVEEDOR.

   ii. Realizar la capacitación en materia de Seguridad de la Información impartida y seguir las buenas prácticas y recomendaciones divulgadas en la misma, garantizar que los datos del Cliente se procesen de forma legal y de acuerdo con los requisitos de seguridad tanto del CLIENTE como del PROVEEDOR.

   iii. Tomar conciencia de la importancia de la seguridad de la información que el PROVEEDOR le confía o pone a su disposición para el desempeño de sus funciones.

   iv. Infórmese y comprométase observar la debida reserva, confidencialidad y secreto respecto de los datos personales a los que, con motivo del ejercicio de sus funciones, tenga acceso. Esta obligación subsistirá aún después de finalizar su relación.

3. Gestión de activos

a. El PROVEEDOR debe tener un inventario de todos los activos utilizados para almacenar o procesar los datos del CLIENTE. Antes de desactivar cualquier dispositivo que contenga datos del CLIENTE, debe borrar de forma segura el dispositivo.

4. Control de acceso

a. El PROVEEDOR deberá contar con procedimientos y soluciones de control de acceso para limitar el acceso a los dispositivos que procesan datos del CLIENTE.

b. Para ello, el PROVEEDOR deberá contar, como mínimo, con las siguientes medidas de seguridad:

i. Procedimiento de alta/registro, modificación y baja/revocación de usuarios con acceso a sistemas o aplicaciones.

ii. Registro o listado de usuarios con acceso a sistemas o aplicaciones, incluyendo todos tiporequisitos de acceso importantes, como acceso a la red, a la nube, acceso móvil y acceso remoto.

iii. Revisión periódica de permisos en sistemas o aplicaciones.

iv. Revisión periódica de accesos a sistemas o aplicaciones.

v. Registro/log de accesos a sistemas/aplicaciones: intentos exitosos y fallidos, accesos con perfil de administrador, modificaciones o borrados de datos realizados.

vi. Se implementó una política de contraseñas segura (longitud, complejidad, historial, etc.)

1. Longitud mínima de la contraseña: 10 caracteres
2. Validez máxima de la contraseña: 60 días
3. Validez mínima de la contraseña: 1 día
4. Tiene en cuenta un historial de contraseñas del usuario al crear la contraseña cuando caduca: 24 contraseñas
5. Reglas de complejidad de contraseñas: mayúsculas, minúsculas, números y símbolos

viii. Política de bloqueo de cuenta después de 10 intentos fallidos: cuentas bloqueadas; política de cierre de sesión después de un período de inactividad

ix. Procedimientos de distribución y restablecimiento de contraseñas que garantizan la seguridad y el no acceso de terceros no autorizados.

x. Sistemas de gestión de acceso de usuarios que permitan garantizar su identificación inequívoca. Todos los usuarios deberán utilizar la autenticación de doble factor y para ello deberán contar con un dispositivo móvil.

5. Criptografía

a. EL PROVEEDOR debe garantizar que todos los datos del CLIENTE estén encriptados, tanto en reposo como en tránsito.

b. El PROVEEDOR deberá contar con procedimientos para el manejo seguro de las claves de cifrado, las cuales podrán ser conservadas por el CLIENTE en caso de ser requerido por éste.

6. Seguridad física y ambiental

a. El PROVEEDOR deberá implementar medidas para controlar el acceso físico a los sistemas de información, sean automatizados o no automatizados (papel). Solamente el personal autorizado por el PROVEEDOR deberá estar autorizado para acceder físicamente a dichos sistemas de información.

b. Las normas de seguridad física deberán incluir, como mínimo, las siguientes medidas:

   i. Tener siempre visibilidad sobre personas no autorizadas a acceder a la información.

   ii. No deje abiertas las puertas de acceso a oficinas o habitaciones si no están supervisadas.

   iii. No dejar pantallas de ordenador u otros sistemas de visualización de datos, así como documentación sobre mesas, a la vista de personas no autorizadas.

   iv. Bloquear las pantallas de los equipos de cómputo siempre que sea necesario ausentarse temporalmente del lugar de trabajo.

   v. No mantener conversaciones relacionadas con los procesos de negocio de la Empresa y/o Clientes en presencia de personas no autorizadas a conocer dicha información.

   vi. No coloque impresoras, escáneres, faxes o dispositivos portátiles o extraíbles como USB, discos duros externos, etc. al alcance de personas distintas al PROVEEDOR.

   vii. No deje correo postal al alcance de usuarios no autorizados.

   viii. Cierre los armarios y las puertas al cerrar la oficina.

ix. Asegure las computadoras portátiles con cerraduras de seguridad al final del día o durante ausencias prolongadas.

c. Además, el acceso a instalaciones sensibles como el centro de procesamiento de datos debe incluir las siguientes medidas:

i. Registro de acceso físico a las instalaciones del PROVEEDOR

ii. Solicitudes de acceso/autorización de acceso a las instalaciones del PROVEEDOR.

iii. Revisión periódica de permisos de acceso.

iv. Sistemas de detección y mitigación de incendios e inundaciones, implantados, con revisiones o pruebas periódicas realizadas.

7. Seguridad de operaciones

a. El PROVEEDOR deberá implementar y operar medidas de protección de los sistemas de información de acuerdo con su normativa de seguridad de la información. Asimismo, deberá incluir al menos los siguientes aspectos:

i. Realizar análisis de vulnerabilidades y pruebas de penetración en todas las aplicaciones e infraestructuras que alojan datos de CLIENTES

ii. Sistemas/aplicaciones con vulnerabilidades mitigadas:

1. El PROVEEDOR contará con un proceso para identificar y gestionar las amenazas cibernéticas y realizará pruebas de seguridad pertinentes de forma periódica. El tipo y frecuencia de dichas pruebas serán presentadas por el PROVEEDOR y convenidas con el CLIENTE. Los resultados de dichas pruebas también deberán ser comunicados al CLIENTE si así lo solicita. El CLIENTE no se verá afectado por pruebas de seguridad y rendimiento ejecutadas por otras partes, como otros Clientes del PROVEEDOR.
2. El PROVEEDOR utilizará un estándar comúnmente aceptado para clasificar las vulnerabilidades,
3. El PROVEEDOR contará con procedimientos para asegurar que las vulnerabilidades técnicas sean evaluadas y mitigadas de manera oportuna y de acuerdo a la normativa interna del Destinatario del

Servicio, a la mayor brevedad posible, pero en un plazo máximo de 30 días para aquellas de severidad crítica/alta, 90 días para aquellas de severidad media y 180 días para aquellas de severidad menor contados desde el día de su identificación.

iii. Sistemas/aplicaciones con los últimos parches o actualizaciones instalados.

iv. Sistemas antimalware:

1. El PROVEEDOR contará con las medidas técnicas adecuadas para mitigar el riesgo de que personas no autorizadas accedan a los sistemas o los infecten con software malicioso. Dichas medidas pueden incluir, entre otras, medidas antivirus basadas en host y en red, software avanzado de protección contra amenazas, cortafuegos, sistemas de detección o prevención de intrusiones (IDS/IPS), etc.
2. Se establecerán procedimientos para garantizar que las soluciones implementadas se mantengan actualizadas en todo momento, funcionen según lo previsto y que las alertas creadas por estas soluciones se monitoreen y se tomen medidas en consecuencia.

v. Sistemas de prevención de fuga de información.

vi. Sistemas de registro de actividades realizadas por los usuarios que permiten la correlación de eventos y generación de alertas.

b. El PROVEEDOR deberá implementar medidas de protección de los puestos de trabajo de acuerdo con sus normas y procedimientos, asegurando el cumplimiento de los siguientes aspectos:

i. Cifrado de discos duros en ordenadores.

ii. Inventario con asignación de propietario de cada activo de inventario y responsabilidades.

iii. Uso adecuado de los activos.

iv. Formateo de información en dispositivos reutilizables.

c. El PROVEEDOR deberá realizar copias de respaldo de conformidad con los procedimientos que haya desarrollado, debiendo los datos estar encriptados en las copias.

Gestión de riesgos

a. El PROVEEDOR analizará los riesgos de la información al menos una vez al año, así como en caso de cambios que puedan afectar la Seguridad de la Información.

b. La metodología de evaluación de riesgos estará documentada y basada en las mejores prácticas. El PROVEEDOR contará con un plan de mitigación de riesgos documentado.

c. El PROVEEDOR documentará los análisis de riesgos y sus decisiones sobre medidas y pondrá a disposición extractos del registro de riesgos relacionados con los servicios prestados a solicitud del CLIENTE.

Ciberseguridad

a. El PROVEEDOR contará con una política y estrategia de ciberseguridad.

b. El PROVEEDOR se asegurará de que exista una asignación clara de responsabilidades en materia de ciberseguridad dentro de sus operaciones.

c. El PROVEEDOR designará una persona responsable de dirigir y coordinar los trabajos de ciberseguridad.

d. Se utilizará un marco de ciberseguridad para garantizar que el trabajo de ciberseguridad realizado por el PROVEEDOR sea estructurado y metódico.

e. El marco de ciberseguridad se basará en las mejores prácticas o estándares, por ejemplo, el Marco de Ciberseguridad del NIST.

f. La capacidad de respuesta cibernética y la resiliencia del servicio prestado serán consistentes con la criticidad y la clasificación de la información del servicio prestado.

g. Los elementos del marco de ciberseguridad se probarán antes y periódicamente después de su uso utilizando diversas metodologías.

Documentación de sistemas informáticos

a. El PROVEEDOR dispondrá de documentación de cada uno de los sistemas informáticos que sean importantes para la operación. Estos sistemas se especificarán en un listado que será revisado y actualizado periódicamente en caso de ser necesario.

8. Seguridad de las comunicaciones

a. El PROVEEDOR deberá implementar medidas de control que minimicen la exposición de los datos del CLIENTE, tanto interna como externamente. Para ello, sus normas y procedimientos deberán considerar al menos los siguientes aspectos:

i. Infraestructura de seguridad perimetral para controlar el acceso a la red corporativa de la empresa.

ii. Cifrado de comunicaciones y/o información saliente de un sistema particular.

iii. Monitoreo y registro de eventos en las comunicaciones.

iv. Protección de elementos de red.

v. Mecanismos de control de acceso y encriptación a través de protocolos de redes inalámbricas seguras.

Comunicación segura de datos de extremo a extremo

La comunicación de datos entre el CLIENTE y el PROVEEDOR, entre los centros de datos del PROVEEDOR, entre los Clientes del CLIENTE y el PROVEEDOR, así como cualquier otro medio de comunicación dentro de los centros de servicio y centros de datos del PROVEEDOR, deberá ser protegida por el PROVEEDOR de extremo a extremo.

9. Adquisiciones, desarrollo y mantenimiento de sistemas de información

a. El PROVEEDOR deberá contar con procedimientos para la revisión y pruebas, tanto funcionales como de seguridad, de los productos de software adquiridos antes de su implementación.

b. El PROVEEDOR deberá contar con un modelo o método de desarrollo seguro que incluya:

i. Seguridad en la fase de diseño (requisitos de seguridad)

ii. Buenas prácticas de desarrollo seguro

iii. Controles de verificación de requisitos

iv. Control de versiones

v. Realizar revisiones de código.

c. Los datos utilizados para las pruebas por parte del PROVEEDOR deberán ser ficticios o, en su caso, anonimizados/disociados.

d. El PROVEEDOR deberá disponer de medidas de almacenamiento seguro y control de acceso al código fuente de los programas.

Prácticas y metodología para el desarrollo y uso de software seguro (si corresponde)

a. EL PROVEEDOR desarrollará y gestionará el software de acuerdo con las mejores prácticas establecidas, por ejemplo, OWASP, seguridad por diseño, garantía de calidad y pruebas de seguridad.

b. El PROVEEDOR no utilizará los datos del CLIENTE para fines de desarrollo y pruebas, salvo autorización expresa del CLIENTE.

c. EL PROVEEDOR adoptará las mejores prácticas de la industria para el modelado de amenazas, como STRIDE, Trike, PASTA o similares, en los procesos de desarrollo para garantizar que se tengan en cuenta las amenazas comunes durante el desarrollo de nuevos sistemas y aplicaciones y la selección de medidas de seguridad.

10. Relación con proveedores

a. El PROVEEDOR, sin perjuicio de las autorizaciones de subcontratación que sean necesarias, deberá contar con procedimientos para identificar, clasificar y evaluar la idoneidad de aquellos terceros por él contratados que pudieran afectar el servicio prestado al CLIENTE o tener acceso a los datos del CLIENTE.

b. Los procedimientos definidos por el PROVEEDOR deberán permitir, como mínimo, validar que se dispone de los siguientes aspectos:

i. Cláusulas relativas a la seguridad de la información en los contratos con proveedores de servicios: requisitos de seguridad en la cadena de suministro y/o servicio TIC.

ii. Acuerdos de Nivel de Servicio con proveedores de servicios TIC: descripción del servicio, nivel de servicio, mecanismos de seguridad, gestión del servicio, gestión del cambio...

iii. Revisiones de acuerdos de nivel de servicio TIC con proveedores: Informes de servicio, auditorías de servicio realizadas.

iv. Existencia de planes adecuados de transferencia de servicios entre proveedores en caso de incumplimientos reiterados de los acuerdos de nivel de servicio.

v. Solicitud a los proveedores de certificados oficiales de acuerdo al estándar de seguridad en función del servicio prestado.

11. Gestión de incidentes de seguridad de la información

a. El PROVEEDOR deberá contar con un procedimiento para gestionar incidentes de seguridad de la información y reportar, identificar y gestionar incidentes, para asegurar una gestión eficaz y estandarizada de los incidentes y aprender de cualquier incidente de seguridad de la información sospechado, real o potencial, relativo a los servicios prestados al CLIENTE (“Incidente de Seguridad”). Este procedimiento deberá incluir también:

i. roles y responsabilidades para diferentes escenarios (por ejemplo, errores, fallos de funcionamiento o ataques cibernéticos);

ii. procedimientos para identificar, analizar y resolver la causa raíz de uno o más incidentes;

iii. procedimientos de respuesta a incidentes para mitigar los impactos relacionados con los incidentes a fin de minimizar la degradación de los servicios; y

iv. Planes de comunicación externa para funciones y procesos empresariales para colaborar con las partes interesadas relevante y recuperarse del incidente a tiempo.

b. Después de tener conocimiento de un Incidente de Seguridad, el PROVEEDOR deberá:

   i. Notificar al CLIENTE lo antes posible, en el plazo máximo de 24 horas;

   ii. Hacer todo lo que esté a su alcance para evitar dicha violación o mitigar sus consecuencias para minimizar el impacto comercial negativo para el CLIENTE;

   iii. Informar continuamente al CLIENTE de las medidas que el PROVEEDOR adopte o vaya a adoptar;

   iv. Obtener la autorización del CLIENTE, por escrito y con antelación, para cualquier comunicación, notificación o anuncio público sobre el Incidente de Seguridad, y

   v. Realizar cualquier acción adicional solicitada por el CLIENTE, incluyendo colaborar en las investigaciones del CLIENTE relacionadas con el Incidente de Seguridad, si lo hubiera.

12. Gestión de la continuidad del negocio

a. El PROVEEDOR deberá contar con un plan de continuidad de negocio documentado y alineado con los requerimientos del CLIENTE a nivel de RTO y RPO del servicio.

b. El PROVEEDOR deberá realizar pruebas del plan de continuidad del negocio y recuperación ante desastres, al menos anualmente.

c. La documentación describirá al menos cómo se utilizarán los sistemas de TI, la funcionalidad, el diseño interno relevante y la descripción de las rutinas operativas.

8 ANEXO C

1. Políticas y regulaciones de seguridad de la información

a. El PROVEEDOR deberá desarrollar, mantener y aplicar medidas de seguridad técnicas, organizativas o lógicas apropiadas para proteger cualquier dato no público del CLIENTE, incluidos los datos personales, del acceso o divulgación no autorizados, la destrucción accidental o ilícita o la pérdida o alteración accidental.

b. EL PROVEEDOR garantiza que el acceso a los datos del CLIENTE para casos de soporte estará restringido a un número limitado de personal autorizado por el CLIENTE, en función de las necesidades del negocio, la necesidad de saber y los privilegios mínimos requeridos.

c. El PROVEEDOR tomará en cuenta la naturaleza, alcance y complejidad de sus operaciones al formular el Reglamento Interno y lo actualizará periódicamente.

d. EL PROVEEDOR no accederá a los Datos del CLIENTE a menos que el CLIENTE lo apruebe.

e. La política y normativa de seguridad de la información del PROVEEDOR deberá estar alineada con los estándares internacionales de referencia, ISO 27002, NIST o similares.

f. El PROVEEDOR deberá contar con las herramientas y recursos necesarios para la implementación de su política y normativa de seguridad de la información.

g. El PROVEEDOR deberá monitorear continuamente el cumplimiento de las políticas y regulaciones de seguridad de la información, y podrá demostrar dicho cumplimiento al CLIENTE cuando sea requerido.

h. El PROVEEDOR debe asignar responsabilidades de seguridad de la información a personas específicas. Sus responsabilidades deben incluir el cumplimiento de la protección de datos, así como el mantenimiento de la confidencialidad, integridad y disponibilidad de los datos y servicios del CLIENTE.

2. Seguridad relacionada con los recursos humanos

a. El PROVEEDOR deberá realizar acciones de concienciación entre su personal y todos aquellos terceros que, en razón del servicio prestado, pudieran tener acceso a la información del CLIENTE.

b. Será responsabilidad del PROVEEDOR que sus empleados o colaboradores:

   i. Conozca cuánta información relativa a la protección de datos pone a su disposición el propio PROVEEDOR.

   ii. Realizar la capacitación en materia de Seguridad de la Información impartida y seguir las buenas prácticas y recomendaciones divulgadas en la misma, garantizar que los datos del Cliente se procesen de forma legal y de acuerdo con los requisitos de seguridad tanto del CLIENTE como del PROVEEDOR

   iii. Tomar conciencia de la importancia de la seguridad de la información que el PROVEEDOR le confía o pone a su disposición para el desempeño de sus funciones.

   iv. Infórmese y comprométase observar la debida reserva, confidencialidad y secreto respecto de los datos personales a los que, con motivo del ejercicio de sus funciones, tenga acceso. Esta obligación subsistirá aún después de finalizar su relación.

3. Control de acceso

a. Los Sistemas de Gestión de acceso de usuarios que permitan garantizar su identificación inequívoca. Todos los usuarios deberán utilizar la autenticación de doble factor y para ello deberán contar con un dispositivo móvil.

4. Seguridad de las comunicaciones

a. El PROVEEDOR deberá implementar medidas de control que minimicen la exposición de los datos del CLIENTE, tanto interna como externamente. Para ello, sus normas y procedimientos deberán considerar al menos los siguientes aspectos:

   i. Infraestructura de seguridad perimetral para controlar el acceso a la red corporativa de la empresa.

ii. Cifrado de comunicaciones y/o información saliente de un sistema particular.

iii. Monitoreo y registro de eventos en las comunicaciones.

iv. Protección de elementos de red.

v. Mecanismos de control de acceso y encriptación a través de protocolos de redes inalámbricas seguras.

Comunicación segura de datos de extremo a extremo

Comunicación de datos entre el CLIENTE y el PROVEEDOR, entre los centros de datos del PROVEEDOR, entre los Clientes del CLIENTE y PROVEEDOR, así como cualquier otra vía de comunicación dentro de los centros de servicio y centros de datos del PROVEEDOR, deberá ser protegida por el PROVEEDOR de extremo a extremo.

5. Adquisiciones, desarrollo y mantenimiento de sistemas de información (aplicable en caso de servicios de desarrollo)

a. El PROVEEDOR deberá contar con procedimientos para la revisión y pruebas, tanto funcionales como de seguridad, de los productos de software adquiridos antes de su implementación.

b. El PROVEEDOR deberá contar con un modelo o método de desarrollo seguro que incluya:

i. Seguridad en la fase de diseño (requisitos de seguridad)

ii. Buenas prácticas de desarrollo seguro

iii. Controles de verificación de requisitos

iv. Control de versiones

v. Realizar revisiones de código.

c. Los datos utilizados para las pruebas por parte del PROVEEDOR deberán ser ficticios o, en su caso, anonimizados/disociados.

d. El PROVEEDOR deberá disponer de medidas de almacenamiento seguro y control de acceso al código fuente de los programas.

Prácticas y metodología para el desarrollo y uso de software seguro (si corresponde)

a. EL PROVEEDOR desarrollará y gestionará el software de acuerdo con las mejores prácticas establecidas, por ejemplo, OWASP, seguridad por diseño, garantía de calidad y pruebas de seguridad.

b. El PROVEEDOR no utilizará los datos del CLIENTE para fines de desarrollo y pruebas, salvo autorización expresa del CLIENTE.

c. EL PROVEEDOR adoptará las mejores prácticas de la industria para el modelado de amenazas, como STRIDE, Trike, PASTA o similares, en los procesos de desarrollo para garantizar que se tengan en cuenta las amenazas comunes durante el desarrollo de nuevos sistemas y aplicaciones y la selección de medidas de seguridad.

6. Relación con proveedores

a. El PROVEEDOR, sin perjuicio de las autorizaciones de subcontratación requeridas, deberá contar con procedimientos para identificar, clasificar y evaluar la idoneidad de aquellos terceros contratados por éste que pudieran afectar el servicio prestado al CLIENTE o tener acceso a los datos del CLIENTE

b. Los procedimientos definidos por el PROVEEDOR deberán permitir, como mínimo, validar que se disponga de los siguientes aspectos:

   i. Cláusulas relativas a la seguridad de la información en los contratos con proveedores de servicios: requisitos de seguridad en la cadena de suministro y/o servicio TIC.

   ii. Acuerdos de Nivel de Servicio con proveedores de servicios TIC: descripción del servicio, nivel de servicio, mecanismos de seguridad, gestión del servicio, gestión del cambio...

   iii. Revisiones de acuerdos de nivel de servicio TIC con proveedores: Informes de servicio, auditorías de servicio realizadas.

   iv. Existencia de planes adecuados de transferencia de servicios entre proveedores en caso de incumplimientos reiterados de los acuerdos de nivel de servicio.

v. Solicitud a los proveedores de certificados oficiales de acuerdo al estándar de seguridad en función del servicio prestado.

7. Gestión de incidentes de seguridad de la información

a. El PROVEEDOR deberá contar con un procedimiento para gestionar incidencias de seguridad de información y reportar, identificar y gestionar incidentes, para asegurar una gestión eficaz y estandarizada de los incidentes y aprender de cualquier incidente de seguridad de la información, sospechado, real o potencial, relacionado con los servicios prestados al CLIENTE (“Incidente de Seguridad”). »). Este procedimiento también debe incluir:

   i. roles y responsabilidades para diferentes escenarios (por ejemplo, errores, fallos de funcionamiento o ataques cibernéticos);

   ii. procedimientos para identificar, analizar y resolver la causa raíz de uno o más incidentes;

   iii. procedimientosRespuesta a incidentes para mitigar los impactos relacionados con incidentes para minimizar la degradación de los servicios; y

   iv. Planes de comunicación externa para funciones yprocesoscon el fin de colaborar con las partes interesadas relevantes y recuperarse del incidente de manera oportuna.

b. Después de tener conocimiento de un Incidente de Seguridad, el PROVEEDOR deberá:

   i. Notificar al CLIENTE lo antes posible, en el plazo máximo de 24 horas.

   ii. Hacer todo lo que esté a su alcance para evitar dicha violación o mitigar sus consecuencias para minimizar el impacto comercial negativo para el CLIENTE;

   iii. Informar continuamente al CLIENTE de las medidas que el PROVEEDOR adopte o vaya a adoptar;

   iv. Obtener la autorización del CLIENTE, por escrito y con antelación, para cualquier comunicación, notificación o anuncio público sobre el Incidente de Seguridad, y

v. Realizar cualquier acción adicional solicitada por el CLIENTE, incluyendo colaborar en las investigaciones del CLIENTE relacionadas con el Incidente de Seguridad, si lo hubiera.

8. Gestión de la continuidad del negocio

a. El PROVEEDOR deberá contar con un plan de continuidad de negocio documentado y alineado con los requerimientos del CLIENTE a nivel de RTO y RPO del servicio.

b. El PROVEEDOR deberá realizar pruebas del plan de continuidad del negocio y recuperación ante desastres, al menos anualmente.

c. La documentación describirá al menos cómo se utilizarán los sistemas de TI, la funcionalidad, el diseño interno relevante y la descripción de las rutinas operativas.

9 ANEXO D

REQUERIMIENTOS SEGURIDAD DE LA INFORMACIÓN	SI	NO
El proveedor tiene acuerdos/cláusulas de confidencialidad para todo su personal y subcontratistas afectados por los servicios contractuales de SPIKA TECH.		
El proveedor tiene un programa de formacion sobre la seguridad de la información para todo el personal.		
El proveedor sigue un estándar para la administración de la seguridad de la información y los controles de seguridad de la información como ISO / IEC27001 / 2, CSC 20 CIS o similar, para proteger la información en términos de confidencialidad e integridad, así como de disponibilidad.		
El proveedor tiene un proceso de gestión de cambios documentado y estructurado para cambios en los sistemas.		
El proveedor dispone de procedimientos de continuidad de negocio, recuperación y gestión de crisis.		
El proveedor tiene un proceso de gestión de incidentes documentado y estructurado para incidentes de seguridad y violaciones de datos.		
El proveedor tiene un proceso de gestion de acceso documentado y estructurado para acceder a los sistemas.		
El proveedor tiene un proceso de gestión de vulnerabilidades documentado y estructurado que incluye análisis periódicos de vulnerabilidades y pruebas de penetración así como la mitigación oportuna (de conformidad con las instrucciones de seguridad de IT de SPIKA) de las vulnerabilidades identificadas.		
Si la prestación de servicios incluye comunicaciones a través de redes públicas, el proveedor utiliza protololos de cifrado como TLS, SSL, SFTP, VPN de cliente, VPN de Site2Site o tecnologías similares para la transferencia de datos hacia y desde el proveedor.		
Si la prestación de servicios incluye un sistema o aplicacion disponible desde Internet, el proveedor ha realizado un test de penetración el proveedor puede proporcionar evidencias del mismo para su revisión.		

Si la prestación de servicios incluye un sistema o aplicación disponible desde Internet, el proveedor ofrece una solución de inicio de sesión único Solución Active Directory / IDaaS		